Universidad Politécnica de San Luis Potosí

Plan de Respuesta ante Incidentes

Presentado por:

Christian Alfredo Morales Meza – 184937

Asignatura: CNO IV Seguridad Informática

Profesor: Servando López Contreras

Fecha de entrega: 13/10/2026

Índice de contenido

Índice de contenido 2
1. Propósito, Alcance y Clasificación 4
1.1 Propósito 4
1.2 Alcance 4
1.3 Concepto de incidente de seguridad 4
1.4 Criterios de severidad y clasificación 5
1.5 Prioridades de respuesta 5
1.6 Condiciones de activación del plan 6
2. Roles y Responsabilidades 6
3. Preparación, Detección y Reporte 7
3.1 Mecanismos de preparación 7
3.2 Fuentes de detección 8
3.3 Recepción de alertas y canales de reporte 8
3.4 Registro de incidentes 8
4. Análisis y Priorización 9
4.1 Triage inicial 9
4.2 Validación 9
4.3 Determinación de alcance 9
4.4 Clasificación y prioridad 9
4.5 Preservación de evidencia 9
4.6 Escalamiento 10
5. Contención 10
5.1 Contención inmediata 10

5.2 Contención prolongada 10
6. Erradicación y Remediación 11
7. Recuperación 11
7.1 Restauración segura 11
7.2 Pruebas antes de reanudar operación 12
7.3 Monitoreo reforzado 12
7.4 Criterios para volver a operación 12
7.5 Mecanismos de rollback 12
8. Coordinación y Comunicación 12
8.1 Escalamiento ejecutivo 12
8.2 Coordinación con el Plan de Comunicación de Crisis 12
8.3 Notificación a autoridades y terceros 13
8.4 Comunicación con responsables internos 13
9. Playbooks Operativos 13
Playbook 1 — Exposición de artefactos, código fuente y metadatos de despliegue 14
Playbook 2 — Control de acceso roto: IDOR, BOLA y escalamiento de privilegios 14
Playbook 3 — Inyección SQL y exfiltración de base de datos 15
Playbook 4 — Cross-Site Scripting almacenado y compromiso de sesiones de usuario 15
Playbook 5 — Abuso de lógica de negocio: pagos y relaciones contractuales 16
Playbook 6 — Compromiso de la red OT/ICS con impacto físico potencial 17
10. Post-Incidente y Mejora 17
10.1 Cierre del incidente 17
10.2 Informe final 18
10.3 Lecciones aprendidas 18
10.4 Acciones correctivas 18

10.5 Métricas 18

10.6 Responsables y seguimiento hasta la resolución 19

Anexo. Referencias metodológicas y documentos relacionados 19

1. Propósito, Alcance y Clasificación

1.1 Propósito

Este plan establece la estrategia y los procedimientos con los que INTERAFAS detecta, analiza, contiene, erradica y se recupera de incidentes de ciberseguridad que afecten al Portal INTERAFAS (web y API), su base de datos, el Centro de Operaciones/HMI y la red operacional OPS-NET-20. Se elabora como respuesta directa a los 20 hallazgos del Informe de Seguridad Ofensiva de INTERAFAS-LAB (9 críticos, 7 altos y 4 medios) y desarrolla, a nivel operativo, la actividad «Gestión de incidentes y comunicación de crisis» de la matriz RACI de la Propuesta de Gobernanza y Seguridad de la Información (SGSI ISO/IEC 27001).

1.2 Alcance

El plan cubre los mismos activos definidos en el alcance del SGSI: el Portal web ciudadano (A-01), la API del portal (A-02), la base de datos interafas (A-03), el servidor Apache y el código fuente (A-04), el pipeline de despliegue (A-05), las cuentas y sesiones (A-06), el Centro de Operaciones/HMI (A-07) y la red OT OPS-NET-20 (A-08), además de su interfaz con el firmware y los controladores de proceso de bombeo (A-09). Quedan fuera del alcance los sistemas administrativos internos sin conexión a OPS-NET-20 y, en la fase de laboratorio, los ataques de denegación de servicio y de ingeniería social contra personas reales.

1.3 Concepto de incidente de seguridad

Siguiendo la definición de ISO/IEC 27000 adoptada en la Propuesta de Gobernanza, un incidente de seguridad es todo evento no deseado que compromete la confidencialidad, integridad o disponibilidad de la información o de las operaciones de INTERAFAS. Se distingue de un evento o alerta: una alerta se convierte en incidente cuando el triage (Sección 4) confirma explotación real o alta probabilidad de ella, no ante cualquier hallazgo automático sin validar.

1.4 Criterios de severidad y clasificación

La severidad reutiliza la escala de criticidad (Crítica / Alta / Media) del Inventario de Vulnerabilidades y la matriz de riesgos 5×5 del SGSI, con un nivel Bajo adicional para desviaciones sin explotación confirmada, de modo que un mismo hallazgo se clasifique igual en los documentos del proyecto.

Nivel	Criterio	Ejemplos observados en INTERAFAS-LAB	Tiempo de respuesta objetivo
SEV-1 Crítico	Compromete datos personales en volumen, interrumpe o pone en riesgo físico el servicio de agua, o afecta la red OT/ICS (seguridad de proceso). Incluye cualquier hallazgo con probabilidad × impacto ≥ 16 en la matriz de riesgos del SGSI.	Cadena RT-15→RT-20 (segmentación IT/OT, HMI sin autenticación, firmware falsificado, carga de setpoint fuera de rango); RT-07 (SQLi, exfiltración de BD); RT-12 (BOLA entre cuentas)	Activación inmediata (≤ 15 min)
SEV-2 Alto	Compromete la confidencialidad o integridad de un conjunto acotado de expedientes o sesiones, o permite escalamiento de privilegios, sin impacto físico inmediato.	RT-01, RT-04, RT-06, RT-08, RT-09, RT-10, RT-13, RT-19	≤ 1 hora; líder técnico + Responsable del SGSI
SEV-3 Medio	Expone información interna o de configuración sin comprometer datos personales ni procesos críticos; requiere corrección pero no detiene el servicio.	RT-02, RT-05, RT-11, RT-14, RT-15	≤ 4 horas hábiles; área técnica responsable
SEV-4 Bajo	Desviación de política funcional o hallazgo de auditoría sin explotación confirmada ni evidencia de impacto.	No conformidades detectadas en la lista de verificación del SGSI (Sección 9 de la Propuesta ISO/IEC 27001)	≤ 5 días hábiles; seguimiento ordinario

1.5 Prioridades de respuesta

- Primero, la seguridad física: cualquier indicio de alteración de un parámetro de proceso (presión, caudal, niveles) sobre A-07, A-08 o A-09 se atiende antes que cualquier otro frente, incluida la preservación de evidencia digital.
- Segundo, la protección de datos personales: expedientes, CURP, domicilio e historial financiero (A-01, A-02, A-03) por la obligación legal de la Ley General de Protección de Datos Personales en Posesión de Sujetos Obligados.
- Tercero, la continuidad del servicio ciudadano: disponibilidad del portal, pagos y trámites.
- Cuarto, la integridad del registro y la reputación institucional, incluida la coordinación con el Plan de Comunicación de Crisis.

1.6 Condiciones de activación del plan

El plan se activa formalmente ante cualquiera de las siguientes condiciones, y la activación corresponde al Líder del incidente (Sección 2):

- Una alerta de las fuentes de detección de la Sección 3 se confirma como incidente real en el triage de la Sección 4.
- Un hallazgo clasificado como SEV-1 o SEV-2 se detecta en producción, replicando el patrón de alguno de los 20 hallazgos de INTERAFAS-LAB.
- Un tercero (proveedor, municipio integrado, ciudadano o autoridad) reporta un posible compromiso por el canal de la Sección 3.3.
- Una auditoría interna o una prueba de restauración (Sección 9 del SGSI) revela evidencia de explotación, no solo de incumplimiento.

2. Roles y Responsabilidades

El Equipo de Respuesta a Incidentes (ERI) se integra con las mismas áreas y personas que hoy ocupan las encargadurías de despacho identificadas en la Propuesta de Gobernanza, para que la responsabilidad ante un incidente recaiga en quien realmente opera cada activo y no en un titular formal pendiente de resolución institucional. La fila «Gestión de incidentes y comunicación de crisis» de la matriz RACI del SGSI asigna la aprobación final (A) a la Dirección General y la ejecución (R) al Responsable del SGSI junto con Tecnologías e Innovación, Monitoreo Operacional y Atención Ciudadana; este plan desglosa esa asignación en funciones operativas.

Rol en el ERI	Quien lo ocupa hoy	Funciones durante el incidente
Líder del incidente (Incident Commander)	Responsable del SGSI (cargo creado en la Propuesta de Gobernanza ISO/IEC 27001)	Convoca al Equipo de Respuesta a Incidentes (ERI), decide la clasificación y prioridad, autoriza la contención y la erradicación dentro de su nivel, mantiene el registro maestro del incidente y es el único punto de reporte hacia la Dirección General.
Patrocinador ejecutivo	Mtra. Valeria Serrano Cruz — Encargada de Despacho, Dirección General	Aprueba decisiones que exceden la autoridad del Líder del incidente (apagar un servicio público, notificar a una autoridad, activar el Plan de Comunicación de Crisis) y asigna recursos extraordinarios.
Responsable técnico — Portal, API y base de datos	Ing. Bruno Ferrer Lozano — Encargado de Despacho, Tecnologías e Innovación	Analiza y contiene incidentes sobre A-01 a A-06 (portal, API, base de datos interafas, servidor Apache, pipeline de despliegue, cuentas y sesiones); ejecuta erradicación y recuperación técnica; coordina con el administrador de la base de datos.

Rol en el ERI	Quien lo ocupa hoy	Funciones durante el incidente
Responsable técnico — OT/ICS y telemetría	Ing. Emilio Navarro Costa — Encargado de Despacho, Monitoreo Operacional	Analiza y contiene incidentes sobre A-07 y A-08 (Centro de Operaciones/HMI, red OT OPS-NET-20); decide el aislamiento de segmento cuando hay riesgo de impacto físico; es el enlace obligatorio antes de cualquier acción sobre la red operacional.
Responsable de proceso físico	Ing. Tomás Rivas Calderón — Encargado de Despacho, Operación Hidráulica	Confirma el estado real del proceso de bombeo y suministro (A-09), autoriza o veta cambios de setpoint durante la recuperación, y decide si procede operación manual mientras el HMI está comprometido.
Enlace jurídico	Lic. Camila Ortega Neri — Encargada de Despacho, Jurídica	Evalúa obligaciones de notificación (Ley General de Protección de Datos Personales en Posesión de Sujetos Obligados, Ley General de Transparencia), decide sobre la denuncia penal cuando aplica el Código Penal Federal (arts. 211 bis 1 a 211 bis 7) y preserva la cadena de custodia de la evidencia con validez legal.
Enlace de comunicación	Mtra. Natalia Correa Vidal — Encargada de Despacho, Atención Ciudadana	Activa y ejecuta el Plan de Comunicación de Crisis cuando el Líder del incidente o la Dirección General lo instruyen; redacta y autoriza mensajes a ciudadanía, municipios y medios; es el único canal de comunicación externa durante el incidente.
Enlace administrativo	C.P. Héctor Salvatierra Ruiz — Encargado de Despacho, Administración	Gestiona recursos y contratos con terceros durante el incidente (proveedores de hosting, firmware, pagos), aplica penalizaciones contractuales cuando corresponde y documenta el costo del incidente para el informe final.
Terceros y proveedores	Proveedores de hosting, firmware (A-05, A-09), pagos (E-04) y municipios integrados (E-09)	Notificados por el enlace administrativo o jurídico según el convenio o contrato vigente; aportan evidencia, aplican parches o revocan accesos de su lado, y participan en la reunión de cierre cuando el incidente los involucró.

3. Preparación, Detección y Reporte

3.1 Mecanismos de preparación

- Inventario vivo de activos y endpoints (incluida el API) mantenido por Tecnologías e Innovación, el mismo exigido por la política funcional PF-02 del SGSI.
- Bitácora centralizada del portal, la API, la base de datos y el HMI, con retención suficiente para reconstruir la línea de tiempo de un incidente (línea base de PF-07).
- Contactos actualizados de los integrantes del ERI, de los proveedores críticos (hosting, firmware, pagos) y de las autoridades aplicables (Sección 8.3), revisados junto con el inventario de activos.
- Capacitación anual del personal (PF-10) que incluya el canal de reporte de este plan y los escenarios de los seis playbooks de la Sección 9.

3.2 Fuentes de detección

- Alertas automáticas del escaneo del document root y del pipeline de despliegue (PF-04, PF-05).
- Revisión trimestral del inventario de API contra el tráfico real (PF-02) y auditoría de cuentas y privilegios (PF-06).
- Bitácora del HMI y del servicio de telemetría, revisada mensualmente (PF-07), y alertas de la segmentación IT/OT (PF-08).
- Conciliación diaria de pagos (PF-14) para detectar abuso de lógica de negocio como el de RT-13.
- Reportes de terceros: ciudadanos a través de Atención Ciudadana, proveedores a través de Administración, municipios integrados a través de los convenios de intercambio (PF-18).

3.3 Recepción de alertas y canales de reporte

Toda persona del organismo, proveedor o ciudadano que detecte un posible incidente lo reporta por el canal más rápido disponible: a Tecnologías e Innovación para hallazgos sobre el portal, la API o la base de datos; a Monitoreo Operacional para cualquier anomalía en el HMI, la telemetría o la red OT; o a Atención Ciudadana cuando el reporte proviene de un ciudadano. Quien recibe el reporte lo escala de inmediato al Líder del incidente, sin esperar a confirmarlo por completo: la confirmación corresponde al triage de la Sección 4, no a quien reporta.

3.4 Registro de incidentes

El Líder del incidente abre un registro único por incidente desde el primer reporte, con folio, fecha y hora, fuente de detección, activos involucrados y severidad preliminar. El registro se actualiza en cada fase del plan y es la base del informe final su cierre requiere la firma del Líder del incidente y, en los incidentes SEV-1, de la Dirección General.

4. Análisis y Priorización

4.1 Triage inicial

El Líder del incidente, con apoyo del responsable técnico del activo afectado, confirma en un plazo máximo de 30 minutos (SEV-1 y SEV-2) o 4 horas (SEV-3) si la alerta corresponde a un incidente real, reutilizando los procedimientos de comprobación del Informe de Seguridad Ofensiva.

4.2 Validación

La validación exige reproducir el indicador técnico del compromiso (una respuesta HTTP anómala, una entrada inesperada en la base de datos o en la bitácora del HMI) antes de escalar la severidad, evitando falsos positivos que activen de forma innecesaria a todo el ERI.

4.3 Determinación de alcance

- Qué activos de los definidos en la Sección 4 de la Propuesta de Gobernanza están comprometidos.
- Si el incidente corresponde a un hallazgo aislado o forma parte de una cadena de ataque, como las documentadas en el Informe de Seguridad Ofensiva (RT-01→RT-14 en el portal y la API; RT-15→RT-20 en el entorno OT/ICS).
- Qué datos personales o información clasificada como confidencial, en el sentido de la Ley General de Transparencia, pudieron exponerse.

4.4 Clasificación y prioridad

El Líder del incidente asigna la severidad con la tabla de la Sección 1.4 y la prioridad con los criterios de la Sección 1.5; ambas quedan en el registro del incidente y determinan qué playbook de la Sección 9 se activa.

4.5 Preservación de evidencia

- Capturar la bitácora, el tráfico de red relevante y, cuando aplique, una copia de la base de datos o de la tabla afectada, siguiendo la misma disciplina de evidencia documentada en cada hallazgo del Informe de Seguridad Ofensiva.

4.6 Escalamiento

Un incidente SEV-3 se escala a SEV-2 o SEV-1 si durante el análisis se confirma acceso a datos personales, persistencia del atacante o cercanía con la red OT; cualquier indicio sobre A-07, A-08 o A-09 escala de forma automática a SEV-1, convoca al responsable de proceso físico y notifica de inmediato a la Dirección General conforme a la Sección 8.1.

5. Contención

5.1 Contención inmediata

Acciones de minutos a pocas horas, autorizadas por el responsable técnico del activo y, en SEV-1, confirmadas por el Líder del incidente, orientadas a detener la explotación activa sin esperar a entender la causa raíz completa:

- Revocar sesiones, tokens o credenciales comprometidas (relevante para RT-06, RT-10, RT-18).
- Bloquear a nivel de firewall o proxy la IP o el patrón de tráfico del origen identificado.
- Retirar temporalmente de producción el endpoint, archivo o funcionalidad explotada (como se haría con los artefactos de RT-01, RT-02 o RT-04).
- Aislar el segmento de red OT OPS-NET-20 del segmento web ante cualquier indicio de bypass de segmentación (RT-16) o de acceso no autorizado al HMI (RT-17), con autorización del responsable técnico de OT y notificación inmediata al responsable de proceso físico.

5.2 Contención prolongada

Acciones de horas a pocos días que sostienen el servicio mientras se prepara la erradicación definitiva, ponderando siempre tres factores: continuidad operativa del servicio de agua, riesgo de que el atacante persista o escale, y preservación de la evidencia recabada en la Sección 4.5.

- Operar en modo degradado o manual el proceso de bombeo si el HMI permanece bajo sospecha, con autorización expresa de Operación Hidráulica.
- Mantener accesos administrativos reforzados (MFA temporal, lista blanca de IP) mientras se corrige la causa raíz de PF-06.

- Congelar cambios de configuración y despliegues no esenciales sobre el activo afectado hasta concluir la erradicación.
- Documentar cada acción de contención en el registro del incidente con hora, responsable y justificación, porque también es evidencia para el informe final.

6. Erradicación y Remediación

La erradicación no se da por concluida con la contención: exige confirmar y eliminar la causa raíz identificada por el responsable técnico, usando como referencia directa las mitigaciones recomendadas para cada hallazgo en el Informe de Seguridad Ofensiva y las políticas funcionales correspondientes del SGSI.

- Corregir la vulnerabilidad de origen (consulta no parametrizada, falta de autorización por objeto, cookie de rol sin firma, verificador de contraseña heredado, archivo residual) aplicando la mitigación ya documentada para el hallazgo equivalente.
- Eliminar cualquier mecanismo de persistencia: cuentas creadas por el atacante, tareas programadas, webshells, reglas de firewall modificadas o firmware no autorizado instalado en el canal de actualización (RT-18, RT-20).
- Rotar credenciales, llaves y secretos expuestos.

Ningún activo regresa a producción sin la validación. Esta validación la autoriza el responsable técnico del activo y, en SEV-1, también el Líder del incidente.

7. Recuperación

7.1 Restauración segura

- Restaurar el activo desde una copia de respaldo íntegra y probada (PF-16) cuando la erradicación no pueda garantizar un estado limpio del sistema en vivo.
- Reincorporar el activo a producción de forma gradual, priorizando funciones críticas (expedientes, pagos, telemetría) sobre funciones secundarias.

7.2 Pruebas antes de reanudar operación

- Repetir las pruebas funcionales y de seguridad equivalentes a las del hallazgo (por ejemplo, la prueba «el usuario A no puede leer ni pagar el objeto del usuario B» de PF-01) antes de declarar el activo operativo.
- Para el entorno OT, confirmar con Operación Hidráulica que los parámetros de proceso están dentro de los límites de ingeniería antes de devolver el control al HMI.

7.3 Monitoreo reforzado

Durante al menos 30 días después de la reanudación (90 días si el incidente fue SEV-1 u ocurrió sobre A-07, A-08 o A-09), el activo recuperado queda bajo monitoreo reforzado.

7.4 Criterios para volver a operación

- El responsable técnico del activo y el Líder del incidente autorizan por escrito la reanudación; en SEV-1, también la Dirección General.

7.5 Mecanismos de rollback

Si el monitoreo reforzado detecta una recaída, el responsable técnico revierte de inmediato al último estado conocido como seguro (snapshot, respaldo o versión anterior del pipeline) y el incidente se reabre con el mismo folio en el registro, regresando a la Sección 5 en lugar de abrir uno nuevo.

8. Coordinación y Comunicación

8.1 Escalamiento ejecutivo

Todo incidente SEV-1 y todo incidente SEV-2 que involucre datos personales se notifica a la Dirección General dentro de la primera hora de confirmado. La Dirección General es quien decide, a propuesta del Líder del incidente, activar el Plan de Comunicación de Crisis, suspender un servicio público o notificar a una autoridad externa.

8.2 Coordinación con el Plan de Comunicación de Crisis

Este plan atiende la dimensión técnica del incidente; el Plan de Comunicación de Crisis, documento independiente del mismo entregable PR03, atiende el mensaje hacia ciudadanía, medios y municipios integrados. El enlace de comunicación (Atención Ciudadana) participa desde la

apertura del registro del incidente para que ambos planes compartan la misma línea de tiempo y no se difunda información que contradiga el estado técnico real del incidente.

8.3 Notificación a autoridades y terceros

- Autoridad de protección de datos personales del Estado de San Luis Potosí, cuando el incidente exponga datos personales (Ley General de Protección de Datos Personales en Posesión de Sujetos Obligados).
- Secretaría Anticorrupción y Buen Gobierno u homóloga estatal en materia de transparencia, cuando el incidente afecte información clasificada como pública o reservada.
- Ministerio Público, cuando el enlace jurídico determine que hay elementos de un delito conforme al Código Penal Federal (arts. 211 bis 1 a 211 bis 7).
- Proveedores de firmware, hosting o pagos cuyo activo (A-05, A-09, E-04, E-05) esté involucrado, notificados por Administración conforme al contrato vigente.
- Municipios integrados, cuando el incidente afecte el intercambio de información regulado por los convenios de PF-18.

8.4 Comunicación con responsables internos

El Líder del incidente envía una actualización breve al resto del ERI al abrir el incidente, al cambiar de fase (contención, erradicación, recuperación) y al cerrarlo; para SEV-1, la actualización es al menos cada 2 horas mientras el incidente está activo. Toda comunicación interna sobre un incidente en curso se mantiene dentro del ERI y no se distribuye de forma más amplia hasta que el enlace de comunicación lo autorice, para no anticipar un mensaje que luego contradiga al Plan de Comunicación de Crisis.

9. Playbooks Operativos

Los seis playbooks siguientes se derivan directamente de los escenarios observados y confirmados en INTERAFAS-LAB. Cada uno agrupa hallazgos con el mismo patrón de explotación y mecanismo de respuesta, para que el ERI pueda actuar sin tener que interpretar primero a qué categoría pertenece un incidente nuevo con el mismo patrón.

Playbook 1 — Exposición de artefactos, código fuente y metadatos de despliegue

PB-01 · Exposición de artefactos, código fuente y metadatos de despliegue [SEV-2 / SEV-3]	
Hallazgos de referencia (INTERAFAS-LAB)	RT-01 (listado de directorio de artefacto de despliegue), RT-02 (token de validación en endpoint de metadatos de build), RT-04 (código fuente vía archivo de respaldo residual), RT-05 (divulgación de información por manejo inadecuado de excepciones)
Disparador / condición de activación	Un escaneo automático, una revisión manual o un reporte externo detecta un archivo, directorio o endpoint de metadatos accesible públicamente que no debería estar en el document root de producción.
Responsables	Responsable técnico — Portal, API y base de datos (ejecuta); Líder del incidente (clasifica)
Acciones inmediatas	Confirmar con una petición directa (igual que la comprobación de RT-01/RT-02/RT-04) qué información expone el archivo o endpoint. Determinar si el artefacto contiene tokens, credenciales, rutas internas o fragmentos de código que habiliten un ataque posterior. Retirar o bloquear el acceso público al recurso de inmediato.
Evidencia a preservar	Copia del archivo o respuesta expuesta, hora de primer acceso detectado en la bitácora, y hash del artefacto antes de retirarlo.
Contención	Eliminar o mover fuera del document root el artefacto, archivo de respaldo o endpoint de metadatos; revocar cualquier token expuesto en él.
Recuperación	Ejecutar el escaneo automático de PF-04 sobre todo el document root para descartar artefactos equivalentes; corregir el manejo de excepciones que exponía información en exportar.php si aplica (RT-05).
Criterio de cierre	El escaneo de PF-04 no reporta artefactos adicionales, el pipeline exige la lista de salida firmada de PF-05 antes del siguiente despliegue, y el responsable técnico confirma por escrito la limpieza del document root.

Playbook 2 — Control de acceso roto: IDOR, BOLA y escalamiento de privilegios

PB-02 · Control de acceso roto: IDOR, BOLA y escalamiento de privilegios [SEV-1 / SEV-2]	
Hallazgos de referencia (INTERAFAS-LAB)	RT-03 (IDOR en el Portal Ciudadano), RT-06 (escalamiento vertical por cookie de rol), RT-09 (path traversal en descarga de documentos), RT-10 (fijación de sesión), RT-12 (BOLA entre cuentas vía parámetro account)
Disparador / condición de activación	Un usuario reporta ver información que no es suya, o la revisión trimestral de PF-01/PF-02 detecta que una prueba de autorización por objeto falló.
Responsables	Responsable técnico — Portal, API y base de datos (ejecuta); enlace jurídico (evalúa exposición de datos personales)
Acciones inmediatas	Identificar el parámetro o cookie manipulable (identificador de expediente, cuenta, rol o sesión) y el alcance real de registros accesibles de forma indebida. Revisar la bitácora para determinar cuántas cuentas distintas fueron consultadas de forma anómala y si hubo descarga masiva. Clasificar como SEV-1 si se confirma acceso efectivo a CURP, domicilio o historial financiero de terceros.
Evidencia a preservar	Registros de bitácora con los identificadores consultados, capturas de la petición/respuesta manipulada y lista de cuentas potencialmente afectadas.
Contención	Revocar las sesiones activas del origen identificado; si el vector es una cookie de rol o de sesión, invalidar de forma global las sesiones emitidas antes de la corrección.

PB-02 · Control de acceso roto: IDOR, BOLA y escalamiento de privilegios [SEV-1 / SEV-2]	
Recuperación	Implementar la verificación de propiedad del objeto en el servidor para el endpoint afectado (PF-01); regenerar el identificador de sesión al autenticar (PF-06) para cerrar la fijación de sesión; repetir la prueba «el usuario A no puede leer ni pagar el objeto del usuario B» antes de reabrir el endpoint.
Criterio de cierre	La prueba de autorización por objeto se ejecuta y pasa, el resultado queda archivado conforme a PF-01, y el enlace jurídico confirma si procede notificación a titulares de datos personales.

Playbook 3 — Inyección SQL y exfiltración de base de datos

PB-03 · Inyección SQL y exfiltración de base de datos [SEV-1]	
Hallazgos de referencia (INTERAFAS-LAB)	RT-07 (inyección SQL ciega basada en booleanos en el validador de referencias de licitación)
Disparador / condición de activación	Un patrón de peticiones con payloads tipo AND '1'='1' / AND '1'='2', un volumen anómalo de consultas sobre un mismo endpoint, o una alerta del motor de base de datos por consultas repetitivas de reconocimiento de esquema.
Responsables	Responsable técnico — Portal, API y base de datos (ejecuta); Líder del incidente (escala); enlace jurídico (evalúa exfiltración de datos personales y financieros)
Acciones inmediatas	Aislar temporalmente el endpoint vulnerable (retirarlo de producción o bloquearlo en el proxy) sin apagar la base de datos completa. Revisar la bitácora de consultas y de la aplicación para reconstruir qué tablas y columnas pudieron leerse, usando como referencia el mismo alcance de 32 tablas documentado en el hallazgo original. Rotar inmediatamente cualquier credencial o token almacenado en las tablas potencialmente leídas.
Evidencia a preservar	Bitácora de peticiones al endpoint, consultas ejecutadas en el motor de base de datos si están disponibles, y copia de las tablas que se determine fueron accedidas.
Contención	Desactivar el endpoint afectado hasta aplicar la corrección; limitar temporalmente los privilegios de la cuenta de aplicación a solo lectura sobre las tablas no esenciales.
Recuperación	Migrar la consulta a sentencias preparadas y aplicar el principio de mínimo privilegio a la cuenta de la aplicación (PF-03); ejecutar revisión de código y análisis estático antes de reabrir el endpoint; auditar las cuentas de base de datos del trimestre.
Criterio de cierre	La revisión de código confirma el uso de consultas parametrizadas, la cuenta de la aplicación no tiene privilegios administrativos, y el enlace jurídico determina si corresponde notificación por exposición de datos personales y financieros.

Playbook 4 — Cross-Site Scripting almacenado y compromiso de sesiones de usuario

PB-04 · Cross-Site Scripting almacenado y compromiso de sesiones de usuario [SEV-2]	
Hallazgos de referencia (INTERAFAS-LAB)	RT-08 (XSS almacenado en el campo de descripción de reportes ciudadanos)
Disparador / condición de activación	Un usuario o personal interno reporta comportamiento inesperado del navegador al abrir un reporte ciudadano, o una revisión de código detecta entrada sin codificar reflejada en la vista de reportes.
Responsables	Responsable técnico — Portal, API y base de datos (ejecuta)

PB-04 · Cross-Site Scripting almacenado y compromiso de sesiones de usuario [SEV-2]	
Acciones inmediatas	Identificar el o los registros de la base de datos que contienen el payload malicioso almacenado. Determinar si el payload ya se ejecutó contra personal interno con privilegios (el escenario de mayor riesgo del hallazgo original) y, de ser así, tratar sus sesiones como potencialmente comprometidas. Retirar o neutralizar temporalmente el campo o la vista afectada mientras se aplica la corrección.
Evidencia a preservar	Copia del payload almacenado, identificación del registro y de la cuenta que lo creó, y lista de sesiones que visualizaron el reporte mientras el payload estuvo activo.
Contención	Eliminar el payload almacenado de la base de datos; revocar las sesiones de cualquier cuenta, especialmente interna, que haya visualizado el reporte comprometido.
Recuperación	Codificar la salida de forma contextual en todos los campos que muestran contenido generado por ciudadanos, configurar una política de Content-Security-Policy y marcar las cookies como seguras (PF-13); repetir la prueba de XSS en el campo corregido.
Criterio de cierre	La prueba de XSS en el campo corregido no se ejecuta, las cabeceras HTTP de seguridad están presentes, y no quedan sesiones internas abiertas que hayan estado expuestas al payload.

Playbook 5 — Abuso de lógica de negocio: pagos

PB-05 · Abuso de lógica de negocio: pagos [SEV-2]	
Hallazgos de referencia (INTERAFAS-LAB)	RT-13 (liquidación de adeudos con importe manipulado), RT-14 (validación insuficiente de relación contrato-proveedor)
Disparador / condición de activación	La conciliación diaria de pagos (PF-14) reporta una diferencia entre el monto facturado y el monto efectivamente liquidado, o se detecta una modificación al padrón de proveedores sin la aprobación esperada.
Responsables	Responsable técnico — Portal, API y base de datos (ejecuta); Administración y Jurídica (evalúan impacto financiero y contractual)
Acciones inmediatas	Aislar las transacciones afectadas sin revertir automáticamente el estado de las facturas, para no perder el rastro del abuso. Revisar la bitácora de la solicitud de pago o de modificación de proveedor para confirmar que el servidor aceptó un valor controlado por el cliente sin revalidarlo. Cuantificar el monto o alcance del fraude con Administración.
Evidencia a preservar	Solicitud interceptada con el campo manipulado, estado de la factura o del padrón antes y después, y registro de la cuenta que realizó la operación.
Contención	Suspender temporalmente el flujo de pago o de edición del padrón afectado hasta aplicar la corrección; marcar como pendientes de revisión manual las facturas o registros tocados en la ventana del incidente.
Recuperación	Revalidar en el servidor el importe contra el saldo real antes de marcar una factura como pagada, y validar roles y aprobaciones para cualquier cambio en el padrón de proveedores (PF-12, PF-14); corregir manualmente los saldos y relaciones afectadas con Administración.
Criterio de cierre	La conciliación diaria vuelve a mostrar cero diferencias abiertas durante al menos cinco días hábiles consecutivos, y Administración confirma la corrección de los registros afectados.

Playbook 6 — Compromiso de la red OT/ICS con impacto físico potencial

PB-06 · Compromiso de la red OT/ICS con impacto físico potencial [SEV-1]	
Hallazgos de referencia (INTERAFAS-LAB)	Cadena RT-15 (exposición de metadatos de diagnóstico) → RT-16 (bypass de segmentación por X-Forwarded-For) → RT-17 (telemetría del HMI sin autenticación) → RT-18 (canal de firmware sin verificación de autenticidad) → RT-19 (sin límite de autorización por activo) → RT-20 (carga de firmware con parámetro fuera de rango)
Disparador / condición de activación	Cualquiera de: tráfico hacia OPS-NET-20 desde un origen con encabezado X-Forwarded-For sospechoso; una sesión de telemetría del HMI sin autenticación de usuario; un intento de actualización de firmware por el canal Basic Auth heredado; o una lectura de presión, caudal o nivel fuera del rango de ingeniería aprobado.
Responsables	Responsable técnico — OT/ICS y telemetría (ejecuta y lidera); responsable de proceso físico (confirma estado del proceso y autoriza modo manual); Dirección General (notificada de inmediato); Líder del incidente (coordina con el resto del ERI)
Acciones inmediatas	Confirmar en el HMI y en campo, con Operación Hidráulica, si el parámetro reportado corresponde a una condición real o a datos falsificados. Si se confirma o no puede descartarse manipulación, pasar de inmediato el proceso a operación manual y suspender la aceptación de comandos remotos sobre A-07/A-09. Notificar a la Dirección General dentro de los primeros 15 minutos.
Evidencia a preservar	Bitácora de telemetría y del canal de firmware, encabezados de las peticiones con X-Forwarded-For sospechoso, hash del paquete de firmware instalado y registro de los valores de presión/caudal antes, durante y después del evento.
Contención	Aislar a nivel de cortafuegos el segmento OPS-NET-20 del segmento web (sin confiar en el encabezado X-Forwarded-For para ninguna decisión de acceso); revocar el acceso del canal de firmware hasta verificar su integridad y autenticidad.
Recuperación	Exigir autenticación propia de sesión en todo servicio del HMI (PF-07); separar de forma definitiva el canal de firmware del canal de parámetros operacionales e implementar verificación de firma digital, además de validar presión y parámetros físicos contra límites de ingeniería hard-coded (PF-09); reforzar la segmentación IT/OT con controles de red reales en lugar de encabezados HTTP (PF-08) y probarla.
Criterio de cierre	La prueba anual de segmentación se repite y pasa, el HMI exige autenticación en todas sus rutas, el firmware instalado tiene firma verificada, el proceso opera dentro de límites de ingeniería de forma sostenida por al menos 72 horas, y Operación Hidráulica certifica el retorno a operación normal.

10. Post-Incidente y Mejora

10.1 Cierre del incidente

El Líder del incidente cierra formalmente el incidente cuando se cumplen los criterios de la Sección 7.4 (o el criterio de cierre específico del playbook activado) y no hay acciones pendientes de contención, erradicación o recuperación. El cierre se registra en el folio del incidente con fecha, hora y firma del Líder del incidente; los incidentes SEV-1 requieren además la firma de la Dirección General.

10.2 Informe final

Dentro de los 10 días hábiles siguientes al cierre, el Líder del incidente entrega a la Dirección General un informe final con línea de tiempo completa, severidad y alcance confirmados, playbook utilizado, acciones de contención/erradicación/recuperación ejecutadas, evidencia preservada, costo estimado (con apoyo de Administración) y determinación jurídica sobre notificaciones realizadas o pendientes.

10.3 Lecciones aprendidas

El ERI se reúne dentro de los 15 días hábiles posteriores al cierre, siguiendo la misma lógica de no conformidad del ciclo de mejora del SGSI, para responder tres preguntas: qué funcionó en la detección y la respuesta, qué no funcionó o se retrasó, y si el incidente reveló un hallazgo o una cadena de ataque no documentada previamente en el Informe de Seguridad Ofensiva.

10.4 Acciones correctivas

Cada lección aprendida que implique un cambio de control, política funcional o playbook se registra como acción correctiva con responsable y plazo, siguiendo el mismo formato de no conformidad que la Sección 10 de la Propuesta de Gobernanza (por ejemplo, el ajuste ya identificado para PF-05, PF-06, PF-10, PF-12, PF-13 y PF-16). Las acciones correctivas derivadas de un incidente real tienen prioridad sobre las derivadas solo de auditoría.

10.5 Métricas

Indicador	Cómo se calcula	Meta
Tiempo medio de detección (MTTD)	Horas entre el evento real y su confirmación en el triage de la Sección 4	Según severidad: ≤ 15 min SEV-1, ≤ 1 h SEV-2
Tiempo medio de contención (MTTC)	Horas entre la confirmación y la primera acción de contención de la Sección 5	≤ 1 h para SEV-1
Tiempo medio de recuperación (MTTR)	Horas entre la confirmación y el retorno a operación conforme a la Sección 7.4	Definido por playbook activado
Incidentes críticos sin acción correctiva abierta más de 30 días	Incidentes SEV-1 con acción correctiva vencida entre el total de incidentes SEV-1 del periodo	0
Recurrencia del mismo vector	Incidentes con el mismo hallazgo de origen (mismo RT o patrón equivalente) en un periodo de 12 meses	0 recurrencias por hallazgo ya remediado

10.6 Responsables y seguimiento hasta la resolución

El Responsable del SGSI da seguimiento mensual al estado de las acciones correctivas abiertas y reporta su avance en la minuta de revisión por la Dirección (la misma instancia prevista en la Sección 7 de la Propuesta de Gobernanza). Una acción correctiva solo se cierra cuando su responsable entrega evidencia equivalente a la exigida en la lista de verificación de auditoría del SGSI; si una acción correctiva deriva de un incidente SEV-1, su cierre se reporta además a la Dirección General de forma específica, fuera de la minuta ordinaria.

Anexo. Referencias metodológicas y documentos relacionados

- CISA — Federal Government Cybersecurity Incident and Vulnerability Response Playbooks.
- ISO/IEC 27035 — Gestión de incidentes de seguridad de la información, citada como norma aplicable en la Propuesta de Gobernanza ISO/IEC 27001.
- NIST SP 800-61 (ciclo preparación–detección y análisis–contención/erradicación/recuperación–actividad post-incidente), estructura adoptada por los playbooks de CISA y reflejada en las Secciones 3 a 10 de este plan.
- Informe Seguridad Ofensiva (MoralesMezaChristianAlfredo_InformeSeguridadOfensiva) — fuente de los 20 hallazgos, severidades y cadenas de ataque que sustentan la Sección 9 de este plan.
- Propuesta de Gobernanza y Seguridad de la Información, SGSI ISO/IEC 27001 (MoralesMezaChristianAlfredo_ISO27) — fuente de los roles, la matriz de riesgos, las políticas funcionales (PF-01 a PF-20) y la matriz RACI que este plan desarrolla a nivel operativo.
- Plan de Comunicación de Crisis — coordina con este plan conforme a la Sección 8.2.